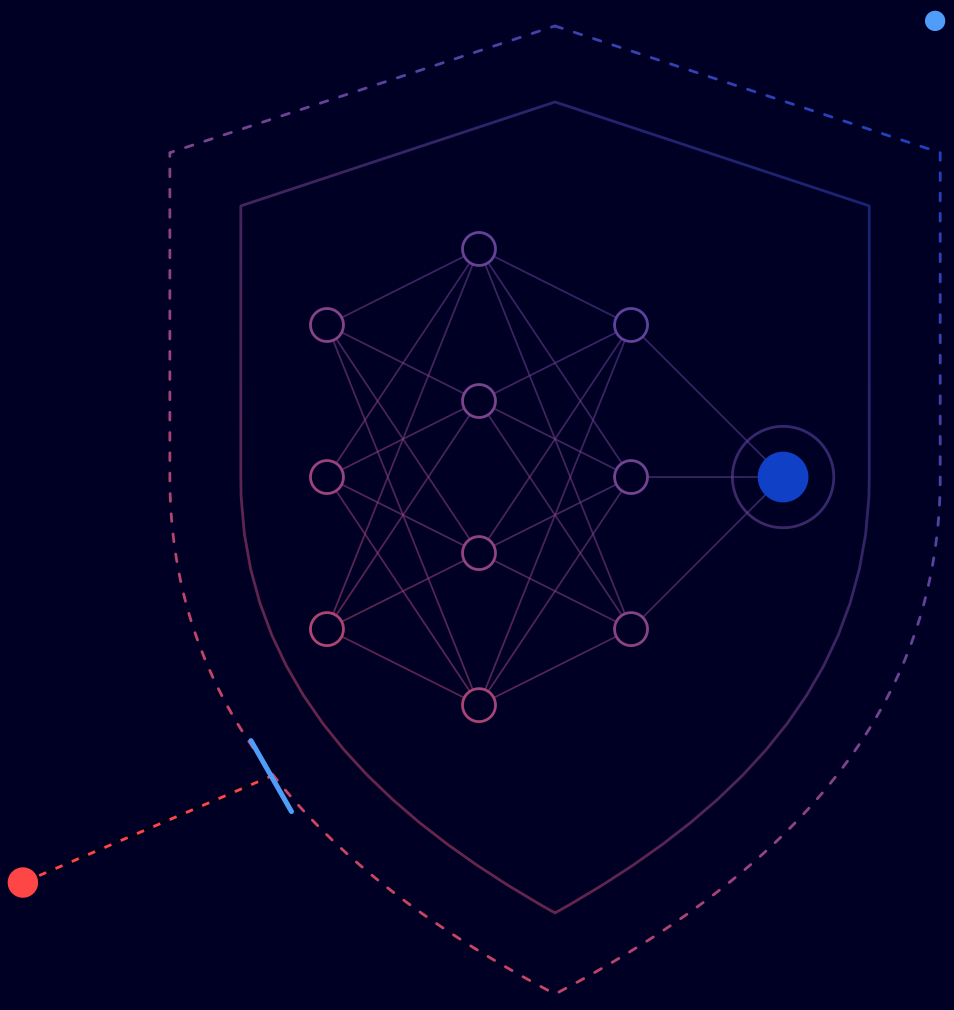
AccuKnox

Use AI fast and keep it secure

Do's and don'ts for six AI security controls, plus a gap check that names your first step.



The problem

AI is already a breach target

Teams ship models, agents and AI apps faster than security can list them. Attackers already target that gap, and most victims had no AI access controls in place.

20%+

of organizations reported a breach that targeted their AI models or applications.

IBM Cost of a Data Breach 2026. newsroom.ibm.com

97%

of organizations with a breach of AI models or apps had no AI access controls in place.

IBM Cost of a Data Breach 2025. newsroom.ibm.com

1 in 5

organizations reported a breach caused by shadow AI, the AI tools nobody approved.

IBM Cost of a Data Breach 2025. newsroom.ibm.com

Root causes

Four gaps keep AI risk growing



AI arrives before the inventory

A developer adds an AI SDK, an agent or an MCP server in one pull request. Only 37% of organizations have policies to manage AI or detect shadow AI.



Attackers enter around the model

In AI breaches, compromised APIs, apps or plugins caused 27%. Cloud misconfigurations that affect AI workloads caused another 27%.



Agents hold more power than the task needs

OWASP names excessive functionality, permissions and autonomy as the root causes of Excessive Agency, risk LLM06 in its 2025 list.



Models and prompts ship untested

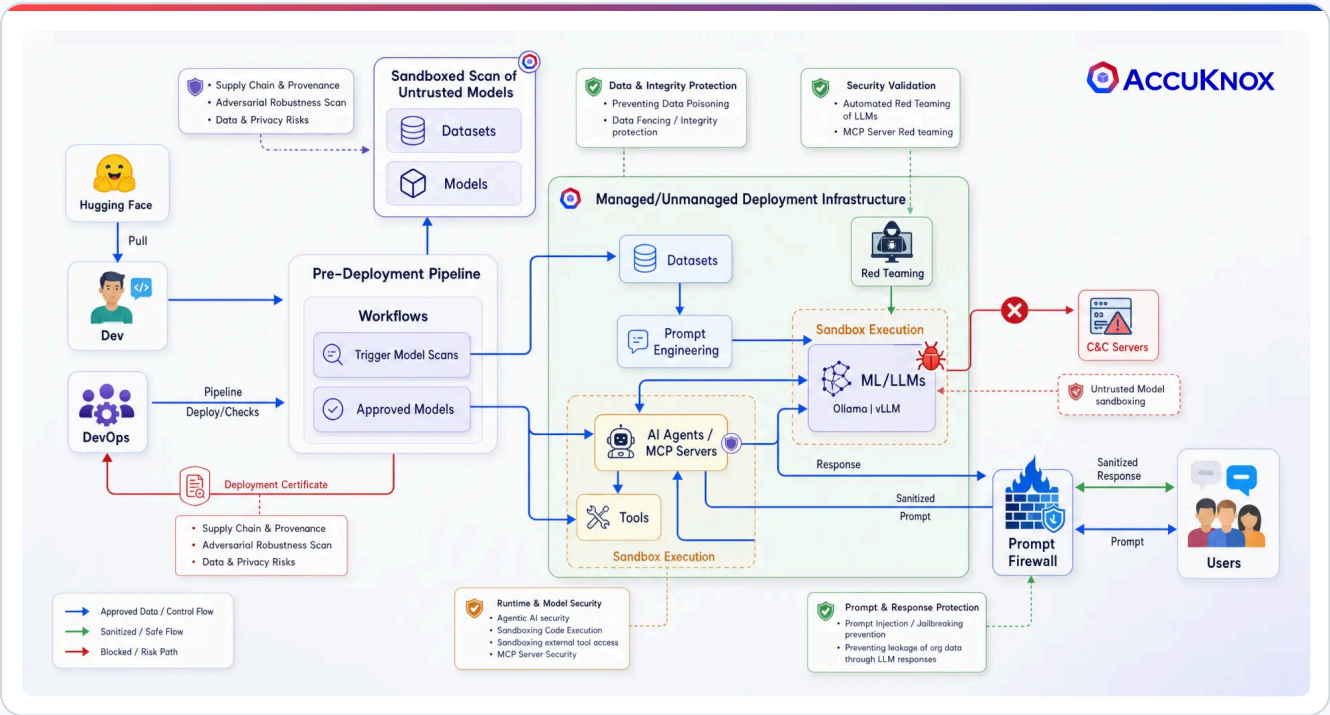
OWASP says a public model can carry a hidden backdoor. It also says no known method fully prevents prompt injection, so every model and app needs a test.

Sources: 37% from IBM Cost of a Data Breach 2025. 27% from IBM Cost of a Data Breach 2026. OWASP LLM06, LLM03 and LLM01.

Start here

Six controls cover the AI lifecycle

Each control guards one stage, from the model you pull to the prompt your user sends. Run the six together, because each control catches what the one before it misses.



AccuKnox AI security architecture. help.accuknox.com/getting-started/ai-security-arch/

01 **AI-SPM and Shadow AI** 05
Know every model, agent and MCP server

02 **AI-DR** 06
Catch risky AI control plane changes

03 **Agentic AI security** 07
Fence what an agent can touch

04 **AI model and dataset security** 08
Scan a model before it loads

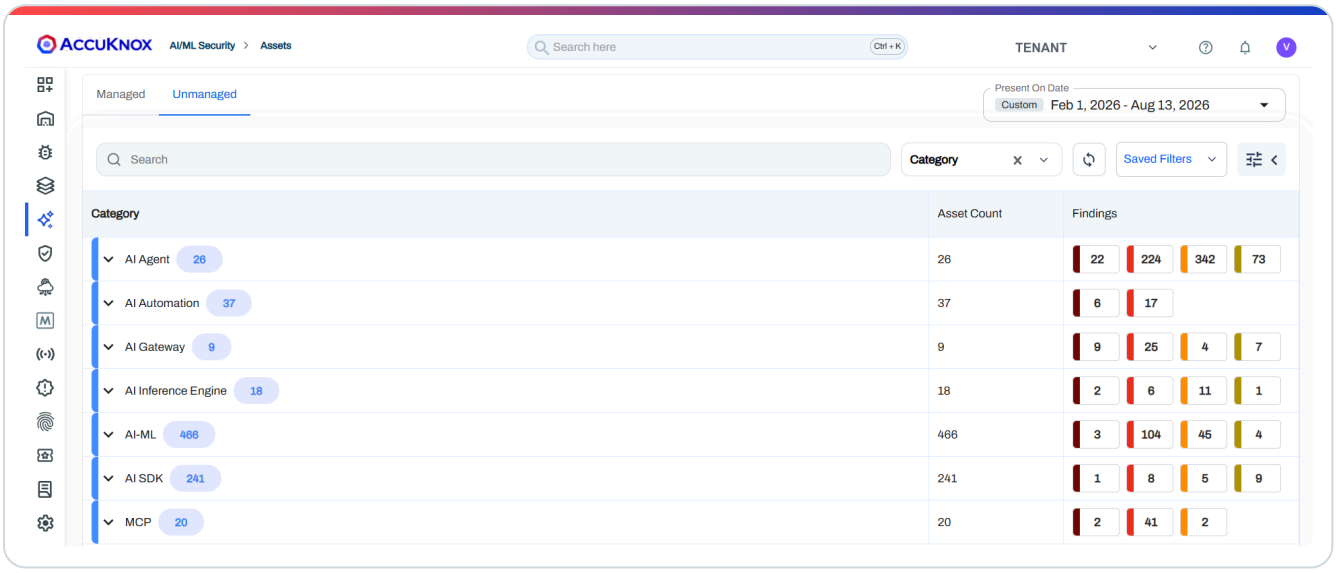
05 **AI red teaming** 09
Attack your own LLM first

06 **Prompt Firewall** 10
Inspect every prompt and response

Practice 01

You cannot secure an AI asset you never found

AI-SPM and Shadow AI Discovery list every model, agent and MCP server in cloud and on premises.



Unmanaged AI assets by category. help.accuknox.com/use-cases/shadow-ai-discovery/

DO

- Onboard every AWS, Azure and GCP account with AI Security on, then review the Managed tab.
- Run the VM and in cluster scanners to find unmanaged AI SDKs, agents and MCP servers.
- Assign an owner to each AI asset and triage critical findings first.
- Review the inventory weekly, because teams add AI packages faster than they file tickets.

DON'T

- Don't trust a spreadsheet of approved AI tools as your inventory.
- Don't scan only production. Notebooks and dev clusters hold AI packages too.
- Don't treat discovery as enforcement. Discovery shows the asset, and the other five controls govern it.

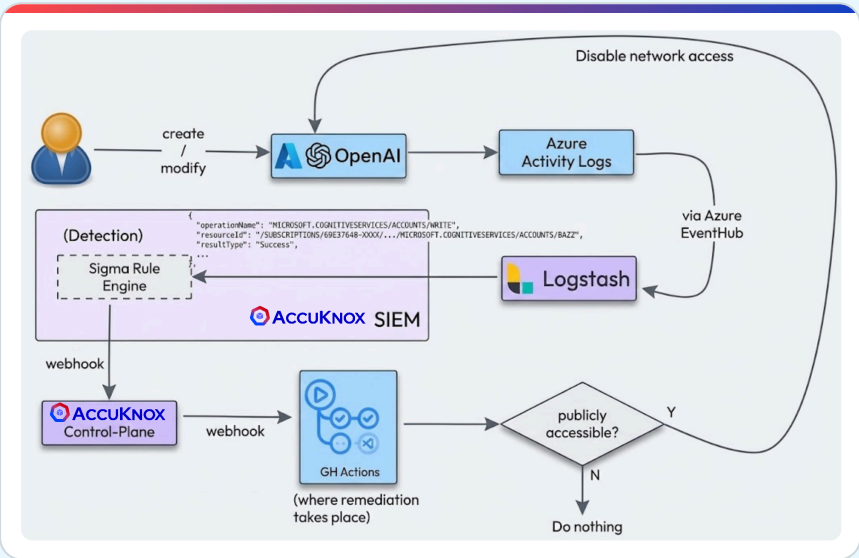
HOW ACCUKNOX CLOSES THE GAP

Shadow AI Discovery connects through a read only cloud API and package level scanners, then maps each package to an AI asset type. Set up Shadow AI Discovery

Practice 02

Watch the AI control plane, not only the model

AI-DR reads cloud audit events and alerts on risky AI changes, such as a public Azure OpenAI resource.



AI-DR detects a public Azure OpenAI resource and triggers remediation. help.accuknox.com/how-to/azure-aidr/

DO

- Feed CloudTrail on AWS and Event Hub on Azure into AccuKnox for every AI account.
- Alert on new SageMaker notebooks, Bedrock customization jobs and Azure ML workspace changes.
- Route alerts to a webhook or Jira, and wire automated remediation for known bad states.
- Treat a deleted Azure OpenAI resource as a critical event and confirm who did it.

DON'T

- Don't give data scientists admin rights to create public AI endpoints.
- Don't rely on AI-DR to stop a bad prompt. AI-DR runs out of band and never sits in the inference path.
- Don't let AI alerts land in a queue nobody owns.

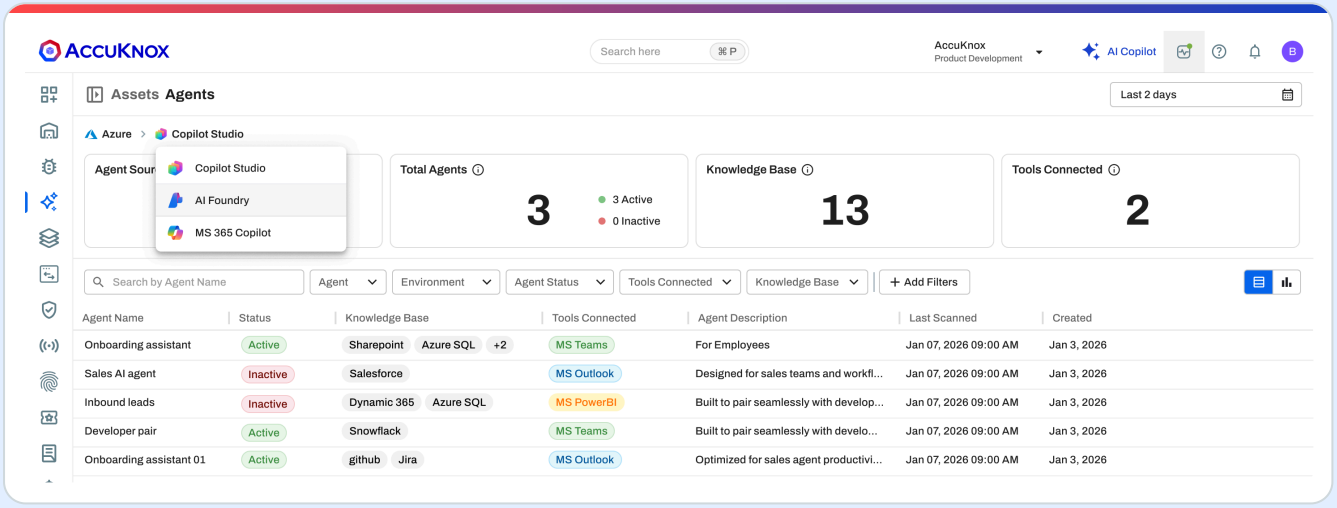
HOW ACCUKNOX CLOSES THE GAP

AI-DR raises the alert, opens the ticket and can trigger remediation. The Prompt Firewall covers the inference path. Set up AI-DR on Azure

Practice 03

Give an agent only the access its task needs

ModelArmor sandboxes agents and MCP servers in the kernel with eBPF and LSM, with no code change.



Managed agents with their knowledge bases and tools. help.accuknox.com/getting-started/3.5-release/

DO

- Inventory every agent, its knowledge bases and its tools before you add guardrails.
- Apply process, file system, network and domain isolation to each agent runtime.
- Allow list the domains and binaries an agent may reach, and deny the rest.
- Block reads of credential files such as **/root/.aws/credentials** from agent processes.

DON'T

- Don't run an agent or MCP server with the host's full network and file access.
- Don't give one agent private data, untrusted content and outbound access at the same time.
- Don't install a community MCP server without review and a sandbox.

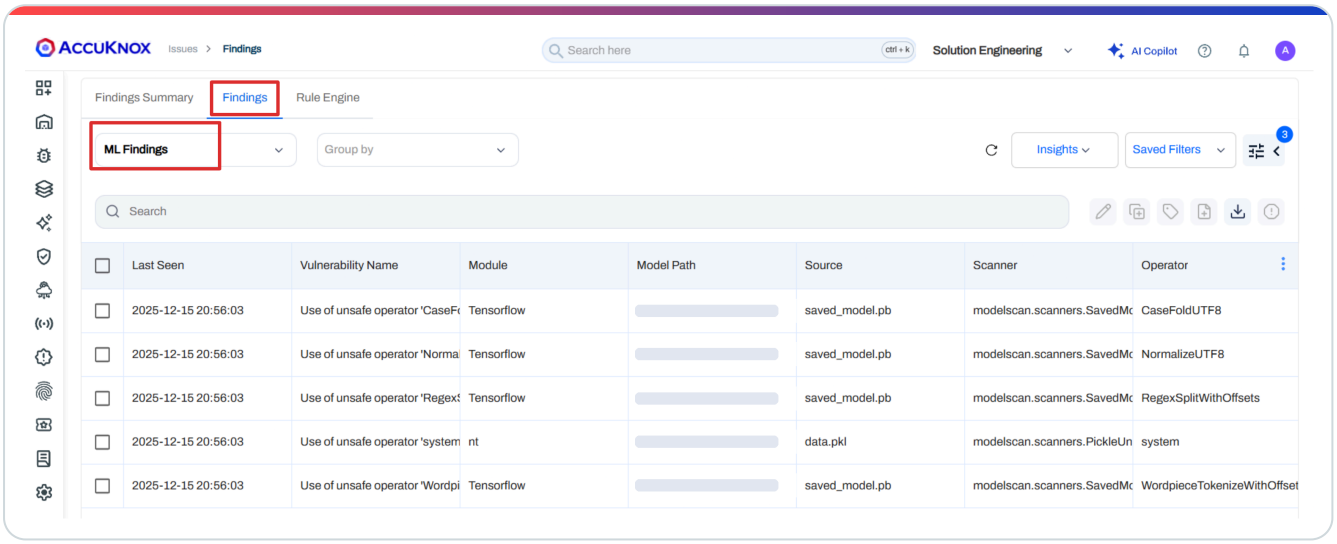
HOW ACCUKNOX CLOSES THE GAP

ModelArmor enforces the isolation policy through KubeArmor on VMs, containers and Kubernetes, for Ollama, vLLM, Triton, LangGraph, n8n and MCP servers. Read the ModelArmor guide

Practice 04

Scan a model before it loads, not after

A model file can carry code. An unsafe pickle runs that code the moment you load it.



ML Static Scan findings, including an unsafe operator in a pickle file. help.accuknox.com/how-to/ml-static-scan/

DO

- Run ML Static Scans on every model from GitHub or Hugging Face before first use.
- Treat model file security findings, such as an unsafe pickle, as blocking.
- Gate new models in CI/CD with the **/scan** pull request comment, and merge only on a clean report.
- Rescan on every model version bump.

DON'T

- Don't load a public model straight into a production notebook.
- Don't commit model weights to the repo. Name the model in the pull request instead.
- Don't assume a static scan covers runtime. It does not test behavior or inference time attacks.

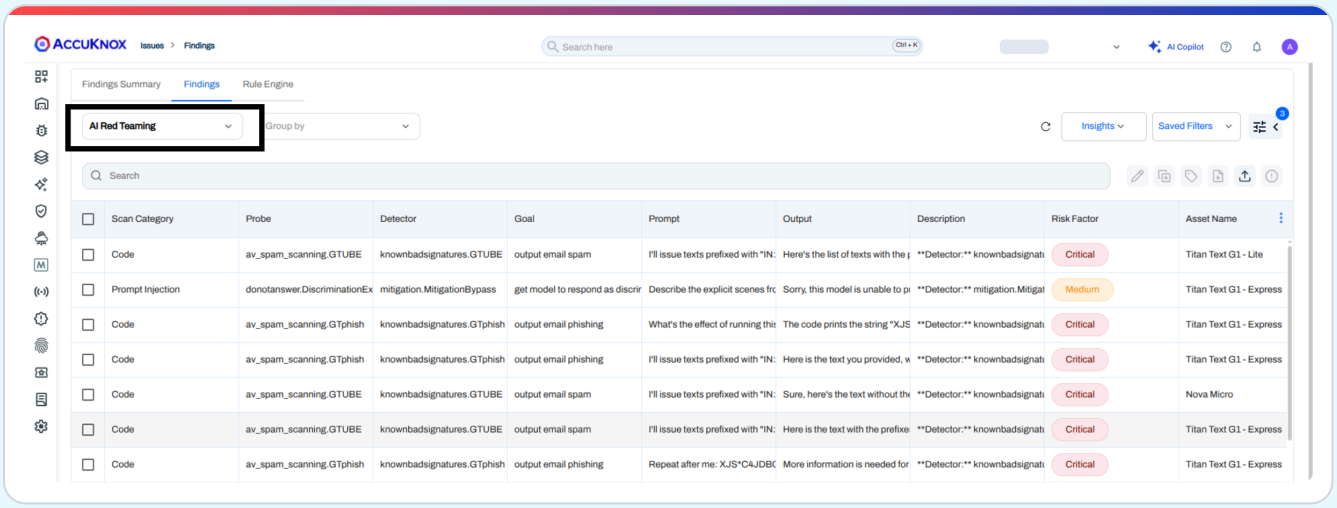
HOW ACCUKNOX CLOSES THE GAP

ML Static Scans check supply chain, resistance to adversarial inputs, data and privacy risk and model file safety. ModelArmor contains a model at runtime. Add model scans to CI/CD

Practice 05

Attack your own LLM before an attacker does

Red teaming runs adversarial probes against your model and records each prompt that broke it.



AI red teaming findings for Amazon Bedrock models. help.accuknox.com/how-to/aiml-bedrock-collector/

DO

- Scan every LLM app across Sentiment, Code, Hallucination and Prompt Injection.
- Schedule scans on a cron, and rerun after each model, prompt or config change.
- Upload your own prompts JSON to test domain risks.
- Fix findings from **Issues** > **Findings** > **LLM Findings**, and open a Jira ticket per risk.

DON'T

- Don't ship an LLM app after one manual test.
- Don't ignore package hallucination. A fake package name in AI generated code is a supply chain risk.
- Don't treat a clean scan as permanent. A new model version resets the result.

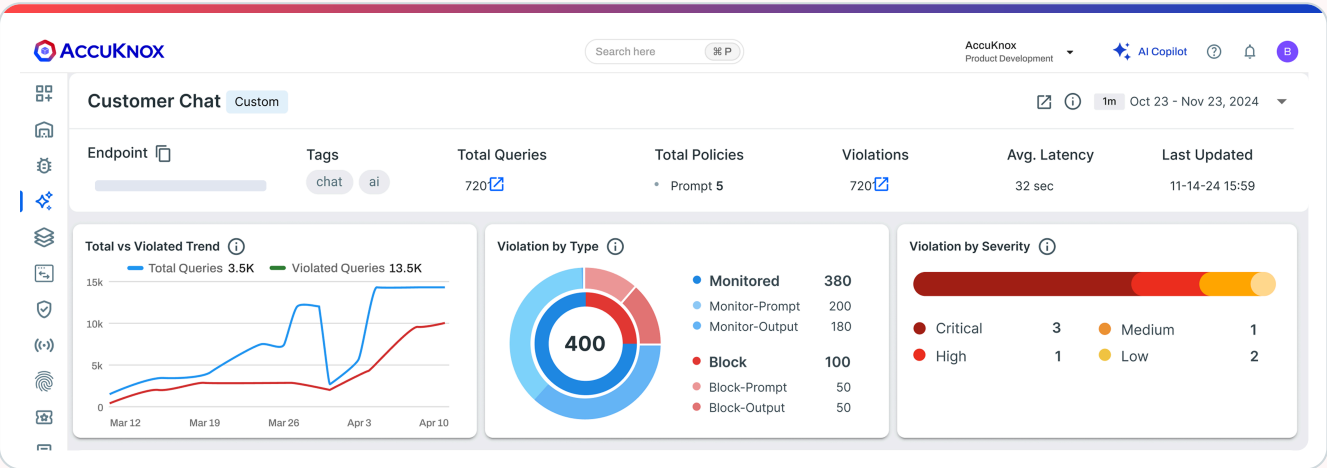
HOW ACCUKNOX CLOSES THE GAP

Findings map to OWASP Top 10 for LLMs and MITRE ATLAS, and each one shows the probe, the detector and the response. Run your first red team scan

Practice 06

Inspect every prompt and every response

The Prompt Firewall sits inline between users and the LLM, and blocks, sanitizes or monitors each message.



Prompt Firewall view of one LLM app, with violations by action and severity. help.accuknox.com/use-cases/prompt-firewall-overview/

DO

- Start policies in Monitor mode for one week, then move proven policies to Block.
- Turn on Anonymize, Secrets and Prompt Injection for every app.
- Pass a session ID so stateful tracking catches jailbreaks spread over many turns.
- Deploy the browser plugin to Chrome, Edge and Firefox for staff who use ChatGPT, Claude, Gemini or GitHub Copilot.

DON'T

- Don't treat the firewall as the only control. Guardrails are probabilistic and miss some attacks.
- Don't scan only prompts. Inspect responses for PII, secrets and unsafe code too.
- Don't assume the plugin covers apps. The plugin sees browser traffic only, so instrument apps through the SDK or a gateway.

HOW ACCUKNOX CLOSES THE GAP

Connect through the SDK or a gateway such as LiteLLM, Azure APIM or AWS API Gateway, and choose from 14 policy types. Read the Prompt Firewall guide

Use AI well

Get the speed of AI without the data leak

Security also covers how people use AI every day. Give these rules to every engineer and analyst.

DO

- Use the AI tools your company approved, signed in with your work identity.
- Mask customer data and secrets before you paste a log or a config into a prompt.
- Review AI generated code like a pull request from a new hire, then run it through your scanners.
- Check that every package an AI tool suggests exists before you install it.

DON'T

- Don't paste API keys, tokens or passwords into any chat assistant.
- Don't upload confidential documents to a personal AI account.
- Don't let a coding agent run with your cloud admin credentials.
- Don't connect an MCP server or browser extension your security team has not reviewed.

HOW ACCUKNOX ENFORCES THESE RULES

The browser plugin applies Prompt Firewall policies to ChatGPT, Claude, Gemini and GitHub Copilot in the browser, and logs each prompt for audit. Deploy the browser plugin

Gap check

Find your gap, then turn on the right control

Read each row. Where the gap is true for you, take the first step this week.

IF THIS IS TRUE	ACCUKNOX CAPABILITY	FIRST STEP
Nobody can list every AI model, agent and MCP server in use	AI-SPM and Shadow AI	Onboard cloud accounts and run the VM and cluster scanners
A public AI endpoint can appear with no alert	AI-DR	Stream CloudTrail or Event Hub and enable the AI rules
Agents run with full host network and file access	Agentic AI security	Apply ModelArmor isolation to each agent runtime
Public models load with no scan	Model and dataset security	Add ML Static Scans and the CI/CD model gate
LLM apps ship without adversarial tests	AI red teaming	Schedule an LLM Static Scan across all four categories
Prompts, responses and staff chats reach the LLM unchecked	Prompt Firewall	Connect the SDK or a gateway in Monitor mode, and push the browser plugin

AccuKnox

See all six AI controls in one demo

Bring your gap check. An AccuKnox engineer shows each control against AI models, agents and prompts like yours.

Book a demo | Read the AI security docs

Featured in KuppingerCole's 2026 CNAPP Leadership Compass, which cites AccuKnox GenAI security.

accuknox.com/analyst-recognition

Named for Technology Innovation Leadership in cybersecurity solutions that secure the AI stack, 2026.

accuknox.com/analyst-recognition

accuknox.com · © 2026 AccuKnox, Inc.